

Security Test Results

Date documented: 2026-06-03

Automated Test Commands

```
.venv/bin/ruff check app tests alembic scripts
.venv/bin/python -m compileall app tests scripts alembic
.venv/bin/bandit -q -r app scripts
.venv/bin/pip-audit --progress-spinner off --cache-dir /private/tmp/pip-audit-cache
.venv/bin/pip-audit --progress-spinner off --cache-dir /private/tmp/pip-audit-cache -r requirements.txt
.venv/bin/alembic current
.venv/bin/alembic upgrade head
.venv/bin/pytest tests/security -vv
.venv/bin/pytest tests/unit tests/integration/test_security_headers.py -q
.venv/bin/pytest tests/unit tests/integration tests/security -q
```

Current Result Summary

The security evidence pack adds pytest tests for authentication, access control, input validation, injection resistance, sensitive data exposure, audit logging, transport hardening, TLS evidence helpers, and rate limiting.

Verification recorded in this workspace on 2026-06-03:

- `.venv/bin/alembic current`: passed; main development database reported 20260602_0003 (head)
- `.venv/bin/alembic upgrade head`: passed; main development database was already at head
- `DATABASE_URL=<test database URL> .venv/bin/alembic upgrade head`: passed; applied all three migrations to `secure_messages_test`
- `DATABASE_URL=<test database URL> .venv/bin/alembic current`: passed; test database reported 20260602_0003 (head)
- `.venv/bin/ruff check app tests alembic scripts`: passed
- `.venv/bin/python -m compileall app tests scripts alembic`: passed
- `.venv/bin/bandit -q -r app scripts`: passed
- `.venv/bin/pip-audit --progress-spinner off --cache-dir /private/tmp/pip-audit-cache`: no known vulnerabilities found
- `.venv/bin/pip-audit --progress-spinner off --cache-dir /private/tmp/pip-audit-cache -r requirements.txt`: no known vulnerabilities found
- `.venv/bin/pytest tests/unit tests/integration tests/security -q`: 327 passed in 16.50s

Area	Evidence	Expected Result
Authentication	tests/security/test_auth_security.py	Generic failures, invalid tokens rejected, refresh rotation enforced
Access control	tests/security/test_access_control_security.py	Users only access direct messages they send or receive
Input validation	tests/security/test_input_validation_security.py	Malformed payloads and unexpected fields rejected
Injection resistance	tests/security/test_input_validation_security.py	Injection-style inputs do not bypass auth or leak DB errors
Sensitive data exposure	tests/security/test_sensitive_data_security.py	Responses and audit logs avoid secrets and plaintext
Rate limiting	tests/security/test_rate_limit_security.py	Repeated abuse returns 429 with safe errors
Blockchain anchors	tests/integration/test_blockchain_routes.py	Pending anchors are created/reused, anchor status is protected by message access, verification checks metadata
TLS utility	tests/unit/test_tls_connection_probe.py	Host resolution/certificate-name formatting utility behavior covered
Security headers / HTTPS	tests/integration/test_security_headers.py	Core hardening headers present, HSTS emitted for HTTPS, HTTPS enforcement covered, wildcard production CORS rejected
Vulnerable components	pip-audit and pip-audit-r requirements.txt	No known vulnerabilities in the backend virtualenv or declared requirements

Key Controls Verified

- Argon2id password hashes are not exposed by API responses.
- Login failures use generic responses.
- JWT access tokens are validated for signature, expiry, type, and subject.
- Refresh-token rotation prevents reuse of old refresh tokens.
- Direct message object-level access checks prevent unrelated access.
- Revocation and per-user delete visibility are enforced.

- Public message APIs reject plaintext-like fields and unsupported conversation/group fields.
- LibSignal-style `wire_payload_json` requires `format=libsignal-v1`, allowed type values, base64 `bodyB64`, and rejects forbidden plaintext/private/session-state keys.
- User lookup hides email, public key material, password hashes, and refresh-token hashes.
- Audit logs record security events without storing passwords, tokens, key material, or encrypted wire payloads.
- Rate limiting mitigates brute-force login, registration spam, refresh abuse, and message spam at a basic local-project level.
- HTTPS enforcement rejects plain HTTP, HSTS is emitted on HTTPS responses, and production settings reject placeholder JWT/refresh-token secrets.
- Bandit produced no findings after suppressing known false positives for non-secret OAuth/hash-prefix literals.
- The backend `virtualenv` and declared requirements currently have no known vulnerabilities according to `pip-audit`.
- Message send and forward now create pending blockchain anchors automatically.
- Blockchain verification checks backend metadata, not live Sepolia state; live Sepolia writes are owned by the separate blockchain worker.

Residual Risks

â- Multi-factor authentication is not implemented.

- Redis-backed session/rate-limit storage is not implemented.
- No admin audit-log viewer is exposed.
- Dependency scan evidence is dated 2026-06-03 and is refreshed after dependency changes.
- Blockchain anchors remain pending until the separate backend worker submits them to Sepolia and updates confirmation metadata.